

[doc. web n. 10039453]
Provision of June 6, 2024
Register of provisions
No. 337 of June 6, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stazione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, on the protection
of natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003,
containing "Code regarding the protection of personal data,
providing provisions for the adaptation of the national
legislation to Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, on the protection of
natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive
95/46/EC" (hereinafter "Code");

HAVING REGARD TO Legislative Decree No. 101 of August 10, 2018,
containing "Provisions for the adaptation of national legislation
to the provisions of Regulation (EU) 2016/679 of the European
Parliament and of the Council, of April 27, 2016, on the protection
of natural persons with regard to the processing of personal data,
as well as the free movement of such data and repealing Directive
95/46/EC";

HAVING REGARD TO Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers entrusted to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web
No. 9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor Regulation No.
1/2000 on the organization and functioning of the office of the
Guarantor for the protection of personal data, doc. web No. 1098801;

Reporting Attorney Guido Scorza;

PREMISED

1. The complaint and notification of violation

With a note dated XX XX, a complaint was made alleging a violation of

the regulations regarding the protection of personal data by the Azienda Usl Romagna, hereinafter "Azienda", resulting from the transmission of her personal data related to HIV infection to the Department of Penitentiary Administration - Rimini District Prison.

In particular, in the aforementioned complaint, accompanied by specific documentation, it was represented that the complainant, who had been certified with a disability of 75%, was assisted by her son-in-law, who had requested from the administration where he worked, the Penitentiary Administration of the Ministry of Justice - Rimini District Prison, the benefits provided by Law No. 104 of February 5, 1992. The aforementioned Administration, in an attempt to carry out sample checks regarding the authenticity of the reports certifying the status of a person with severe disability pursuant to Article 3, paragraph 3, of the aforementioned Law No. 104/1992 produced by staff who benefited from the provisions of the aforementioned law, requested the Azienda to "confirm or not the existence in the records of a report certifying the handicap status of the complainant." Following this request, the Azienda provided a response by transmitting "a copy of the report under Law 104/92 present in the AUSL file of XX." The copy of the report sent (...) with the aforementioned communication was composed of a complete photographic reproduction of the report from the Medical Commission "in clear", fully readable and without any type of masking, with the complete medical history and the assessment of the handicap. From this report, (...) sent to the prison administration in a complete and fully readable version, it emerges unequivocally that among the pathologies suffered by the undersigned is also the HIV infection and the HIV-related nephropathy."

Following the request for information from this Office of XX (prot. No. XX), the Azienda provided a response with a note dated XX, stating that:

- "It should be noted that the request from XX coming from the Rimini District Prison Administration was initially responded to on November 13 by the Civil Invalidity Secretariat located in Cesena – pertaining to the U.O. Legal Medicine and Risk Management - informing of the existence of a report dated XX and simultaneously communicating the assessment contained in the report itself";
- "On XX, however, a request was received from the Rimini District Prison, via email sent directly to the Civil Invalidity Secretariat in Cesena, for the transmission of the report of XX in order to allow the necessary checks, to which the Civil Invalidity Secretariat operator, induced by the

nature of the Public Administration of the requesting entity to consider the positive response necessary also in the spirit of collaboration between entities, responded on December 16 by sending the requested report containing, on the back, due to mere material error, also the medical history and objective examination in clear";

- "As for the context in which it is... the following:

the accidental sending, as known, autumn XX was a moment of particular resurgence of the Covid pandemic and the Civil Invalids Secretariat of Cesena found itself in a situation of particular distress due to staff shortages caused by quarantine measures for Covid positivity, as a result of which the only operators present had to take on activities that were not strictly within their competence, as occurred in the specific case";

- "upon becoming aware of the event, the Company adopted a series of improvement actions, which are in addition to the technical and organizational measures already in place at the time of the event (...), aimed at ensuring greater protection of personal data in the specific area of reference. Indeed, meetings and service meetings were organized regarding the procedures and operational methods for issuing copies of documents and reports from the medical-legal commissions, with particular reference to the rules to be respected regarding confidentiality and the protection of health data and enhanced protection of data related to HIV infection. Furthermore, periodic training/informative sessions are held with the administrative operators of the U.O., for the regular update on the regulatory provisions and company regulations in this area. In addition, the Management of the U.O. Legal Medicine and Risk Management has provided that the reference Function and the Central Secretariat of the U.O. monitor and manage all requests received and the related responses, and has adopted precise provisions addressed to all administrative operators so that, for the management of access requests and for any case of particular relevance and sensitivity, they always refer to the holder of the Function and the Central Secretariat";

- "there is no evidence of any violation of rights by this Company, but only a mere material error by an operator not specifically trained to respond to requests for documentation, determined by the particularly critical situation described above";

- "in light of the adverse event in context, this Company has implemented technical and organizational measures aimed at greater security of personal data and strict compliance with the regulations in this area".

In relation to the issue subject to the complaint, the Company had, on date XX, notified a violation of personal data, stating, among other things, that:

- "the civil invalids secretariat, headquarters of Cesena of the U.O. Legal Medicine and Risk Management on date XX transmitted to the Rimini Prison, upon specific request from the same aimed at verifying the requirements for the right to the benefits of permits L.104/92 of one of its employees, a report relating to L.104/92 concerning a relative of the same. The document sent by mistake contained on the back also anamnesis and objective examination in clear text. This was due to the inattention of the operator who did not deactivate the double-sided printing function, thus producing the printing of the report for the interested party (where health data is omitted) and on the back of the same sheet part of the following report of the same person containing health data. It should be clarified that the fact occurred at a particularly critical moment for the emergency of the second wave of COVID-19. In fact, the civil invalids secretariat in Cesena was working with reduced resources due to quarantine measures for COVID positivity requiring the support of other operators not specifically assigned to the secretarial support of the Invalidity Commissions, as occurred in the specific case in context";

- "with Law 102/2009, from 1.1.2010, the administrative process for the recognition of civil disability, handicap, blindness, and deafness is the responsibility of INPS, including the sending of the reports of the visits, acting as a verification body while the ASLs have remained responsible for the organization

of the health part (constitution of the Commissions and organization of the sessions)”.

2. Assessments of the Department on the treatment carried out and notification of the violation referred to in Article 166, paragraph 5 of the Code

In relation to the facts described in the complaint and in the notification of violation, the Office, with note of XX (prot. n. XX), notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation, inviting it to produce to the Guarantor defensive writings or documents or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981). This, as it was deemed that the Company had carried out processing of health data, including those relating to HIV infection, in violation of the basic principles of processing referred to in Article 5, paragraph 1, letter c) and f) of the Regulation, of the obligations regarding security provided for by Article 32 of the same Regulation, as well as Article 75 of the Code, in relation to the specific sector provisions concerning urgent interventions for the prevention and fight against AIDS (Article 5, paragraph 4 and Article 1, paragraph 2, Law June 5, 1990, No. 135).

With note of XX, the Company submitted its defensive memoranda, in which, while confirming what had already been expressed in note of XX, it highlighted, in particular, that:

- “on date XX this Company received a request for damages from the lawyer of Mr. XX and Mr. XX in relation to the erroneous communication to the Management of the Rimini Prison of health data of XX”;

- “following internal investigation, it was learned...

communication, the Administration took immediate action to mitigate any potential consequences, ensuring that further measures were implemented to prevent similar occurrences in the future.”

- “In conclusion, while the incident is regrettable, it is essential to consider the extraordinary circumstances under which it occurred. The actions taken by the operator were not driven by negligence but rather by the necessity to respond to an urgent request in a challenging environment. Therefore, the responsibility for the incident should not rest solely with the Administration, but rather be viewed in the context of the broader operational challenges faced during the pandemic.”

the principle of which personal data must be “processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures” (art. 5, par. 1, lett. f) of the Regulation).

4. Conclusion

In light of the above observations, it is concluded that the processing of personal data in the context described must comply with the principles established by the Regulation and the applicable national legislation. The Company must ensure that any processing of sensitive data, particularly health-related data, is justified under the legal bases provided for in the Regulation and that appropriate safeguards are in place to protect the rights of the data subjects involved.

The Company is also reminded of its obligation to implement corrective actions to prevent the recurrence of similar non-compliance issues in the future, as well as to maintain transparency and accountability in its data processing activities.

This document serves as a formal communication of the findings and conclusions drawn from the investigation into the data processing activities of the Company, and it is expected that the necessary measures will be taken to align with the legal requirements and protect the rights of individuals whose data is being processed.

which data must be “processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage” (Article 5, paragraph 1, letters c) and f) of the Regulation). The adequacy of such measures must be assessed by the data controller with respect to the nature of the data, the subject matter, the purposes of the processing, and the risk to the rights and freedoms of the data subjects, taking into account the risks arising from the destruction, loss, alteration, unauthorized disclosure, or access to personal data

(Article 32, paragraphs 1 and 2 of the Regulation, Recital No. 83);

7. The Authority has, on several occasions, specified, in protection of persons with disabilities, that “in implementation of the principles of relevance, non-excessiveness, and necessity, in the certifications requested by the data subject [...] it is not necessary to indicate the personal data related to the diagnosis established during the medical examination” (Provision of March 21, 2007, web doc No. 1395821; see also provisions of April 21, 2009, web doc No. 1616870; November 9, 2005, web doc No. 1191411; point 4.2 of the provision of February 16, 2011, web doc No. 1792975; see also provision of July 4, 2013, No. 331, web doc No. 2536504, in which it was reiterated that it is necessary for medical commissions to issue, for the purpose of issuing the disability badge as well as for the tax benefits related to vehicles provided for persons with disabilities, a copy of the minutes omitting the parts dedicated to the description of the anamnesis data, the objective examination, and the diagnosis of the person with a disability);

8. The legislator has provided for enhanced protection for the processing of data related to HIV infection, on one hand, by imposing the obligation to communicate the results of direct or indirect diagnostic tests for the aforementioned infection only to the person to whom such tests refer, and on the other hand, by introducing the obligation for the healthcare operator and any other person who becomes aware of a case of AIDS or HIV infection to adopt all measures or precautions for the protection of the rights of the person and their dignity (Article 5, paragraph 4 and Article 1, paragraph 2, Law of June 5, 1990, No. 135; in this regard, see also Cass. civil, section III, January 30, 2009, No. 2468, according to which “pursuant to (...) Law Article 5, paragraph 1, it is the duty of healthcare personnel to demonstrate that they have adopted all necessary measures to ensure the patient’s right to confidentiality and to prevent data related to the test results and the health conditions of the patient from being disclosed to third parties”);

9. The aforementioned regulatory provision falls within the specific sectoral provisions exempted by Article 75 of the Code, which summarizes the conditions for the processing of personal data in the healthcare sector. The described confidentiality regime has, moreover, been reiterated several times by the Authority in various interventions, qualifying such data as those subject to “greater protection of anonymity” (opinion on the draft decree regarding the electronic health record, of May 22, 2014, web doc No. 3230826; Guidelines on Health Dossier, of June 4, 2015, web doc No. 4084632).

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation – and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Authority, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code “Falsehood in declarations to the Authority and interruption of the execution of the tasks or exercise of the powers of the Authority” – it is represented that the elements provided by the Company in the notification of violation and in the defensive memoranda do not allow overcoming the observations notified by the Office with the aforementioned initiation act of the proceeding, nor do any of the cases provided for by Article 11 of the Authority Regulation No. 1/2019 apply.

As described above, the failure to adopt a measure aimed at verifying the content of the attachments to be transmitted resulted in the Company transmitting the minutes including data related to the HIV infection of the complainant to the Department of Penitentiary Administration - Rimini Prison Directorate, where the complainant's son-in-law, who had requested the benefits provided for by Article 3, paragraph 3, of Law No. 104/1992 to assist her in relation to her disability, was performing his professional activity. This resulted in the processing of health data in violation of the principle of minimization; in compliance with the aforementioned principle, in fact, the Company should have provided the requesting Administration with confirmation of the existence or non-existence of the severity requirement of the woman’s disability, required by the regulations to access the described benefits, but not the entire documentation, including the diagnosis, with anamnesis and objective examination, in clear terms.

Furthermore, in compliance with the principle of integrity and confidentiality of data and the obligation

to adopt appropriate technical and organizational measures to ensure a level of security adequate to the risk, considering the particular category of data processed, subject to greater protection, the Company should have provided specific instructions to the operator called to carry out the processing in question. In this regard, concerning the error that the operator would have made, there is no condition that allows us to assert that the same error was inevitable and unintentional, that is, such that it could have been avoided with ordinary diligence.

In light of established case law of the Supreme Court (Cass. n. 7885/2011, Cass. n. 16320/2010, Cass. n. 19759/2015, Cass. n. 33441/2019, and Cass. n. 17822/2021), for the purposes of applying the invoked Article 3 of Law No. 689/1981, it is necessary that good faith or error be based on a positive element, external to the agent and capable of determining in him the conviction of the lawfulness of his behavior (excusable error). This positive element must be such that it cannot be avoided by the agent through the use of ordinary diligence. In the specific case, the duly trained operator could have diligently verified, through a more accurate check, that he had not deactivated the double-sided printing function, thus avoiding attaching, in addition to the printout of the report for the interested party (where health data is omitted), also the part of the report containing the anamnesis and the objective examination in clear terms (see also European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, par. 4.2.2., which highlights that certain circumstances, including human error, “may indicate negligence”).

Therefore, considering that the arguments put forward by the Company are not sufficient to exclude its liability in relation to the contested matters, the unlawfulness of the processing of personal data carried out by the data controller is noted, as detailed in the reasoning.

In this context, considering, in any case, that the conduct has exhausted its effects and that the Company has declared that it has promptly activated improvement actions to prevent the recurrence of the complained conduct, the prerequisites for the adoption of measures, of a prescriptive or prohibitory nature, pursuant to Article 58, par. 2, of the Regulation, do not exist.

4. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, par. 2, lett. i) and 83 of the Regulation; Article 166, comma 7, of the Code).

The violation of Articles 5, par. 1, lett. c) and f) and 32 of the Regulation, as well as Article 75 of the Code, is subject to the application of the administrative pecuniary sanction pursuant to Article 83, par. 5 of the Regulation.

It should be noted that the Authority, pursuant to Articles 58, par. 2, lett. i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures [referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case] and, in this context, “the Board [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, comma 7, of the Code” (Article 16, comma 1, of the Regulation of the Authority No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, par. 1, of the Regulation, based on the elements provided for in Article 83, par. 2, of the Regulation.

In light of the above and, in particular, of the category of personal data involved in the violation, which falls within the data considered to be of greater protection, the number of affected individuals (1), and the unintentional nature of the violation, it is believed that the level of severity of the violation committed by the Company is high (see European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60).

That said, considering certain elements as a whole and, in particular, that:

- the Authority became aware of the event following the notification of the violation made by the Company, pursuant to Article 33 of the Regulation, and from a subsequent complaint by the interested party (Article 83, par. 2, lett. h) of the Regulation);
- the data controller, in order to prevent the recurrence of the event, has committed to implementing training activities for authorized operators for the processing of personal data (Article 83, par. 2, lett. c) and f) of the Regulation);
- the Company has already been subject to sanctioning measures in relation to relevant violations (provision of January 27, 2021, n. 36, web doc n. 9544504 and May 27, 2021, n. 211, web doc n. 9682619) (Article 83, par. 2, lett. e) of the Regulation);
- the violation concerned a specific internal structure of the data controller and not the overall organization thereof and was determined by an error of an operator (Article 83, par. 2, lett. k) of the Regulation);
- the event occurred within the context of a secretarial employment, by personnel not ordinarily assigned to such activity, within an organizational change undertaken by the Company during the pandemic period, to cope with the absences of operators affected by quarantine measures due to Sars CoV 2 positivity (Article 83, par. 2, lett. k) of the Regulation);

it is deemed appropriate to determine the amount of the pecuniary sanction provided for by Article 83, par. 5 of the Regulation, in the amount of €24,000.00 (twenty-four thousand) for the violation of Articles 5 and 32 of the same Regulation, as well as Article 75 of the Code, as an administrative pecuniary sanction deemed, pursuant to Article 83, par. 1, of the Regulation, effective, proportionate, and deterrent.

It is also considered that the accessory sanction of publication on the website of the Guarantor of this provision should be applied, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Guarantor's Regulation No. 1/2019, also in consideration of the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

ALL OF THE ABOVE CONSIDERED, THE GUARANTOR

declares the unlawfulness of the processing of personal data carried out by the Azienda UsI Romagna, for the violation of the basic principles of processing referred to in Article 5, paragraph 1, letters c) and f) and the obligations referred to in Article 32 of the Regulation, as well as Article 75 of the Code, in the terms set out in the reasoning;

ORDERS

the Azienda UsI Romagna, with legal headquarters at Sede Legale: Via De Gasperi n. 8 – 48121 Ravenna, C.F./P.IVA n. 02483810392, to pay the sum of euro 24,000.00 (twenty-four thousand/00) as an administrative pecuniary sanction, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, for the violation indicated in this provision; it is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

ORDERS

the aforementioned Company, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of euro 24,000.00 (twenty-four thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/1981;

DISPOSES

the full publication of this provision on the Guarantor's website, pursuant to Article 166, paragraph 7, of the Code, and considers that the conditions for annotation in the internal register of the Authority referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external

relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, an appeal against this provision may be brought before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, June 6, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei